

Narrativa explicativa del marco GQM + PRAGMATIC para indicadores SOAR

Hablar de indicadores de ciberseguridad sin un método es como discutir sobre la climatología con una colección de proverbios: entretenido, pero poco operativo. El tándem **GQM + PRAGMATIC** intenta precisamente lo contrario: poner orden, preguntando primero “para qué”, luego “qué queremos saber” y solo al final “qué número vamos a mirar”.^[web:22]^[web:24]

1. De los objetivos país a los logs del SOC

El enfoque **GQM (Goal-Question-Metric)** nos obliga a empezar en el lugar correcto: los objetivos nacionales. No es lo mismo medir para satisfacer un informe regulatorio que para saber si el tiempo medio de permanencia de un atacante en redes OT se está reduciendo año tras año.^[web:13]^[web:10]

En este marco, los objetivos se agrupan en cuatro grandes familias: tiempo, automatización, cumplimiento e impacto económico. Cada familia se traduce en preguntas que alguien razonable podría hacer en una comisión parlamentaria o en un comité de dirección sin que le miren raro. Solo después aparece la métrica: MTTD, porcentaje de alertas automatizadas, tiempo a notificación, ROI de SOAR.^[web:24]^[web:16]^[web:39]

La gracia es que este encadenamiento evita la proliferación de indicadores “por si acaso” que nunca llegan a influir en decisiones: si una métrica no responde de forma clara a una pregunta relevante para un objetivo concreto, se descarta o se aparca en la categoría de experimento.

2. PRAGMATIC: nueve filtros contra la inflación de métricas

Una vez definido el menú de métricas, entra en juego el acrónimo **PRAGMATIC**, algo así como un comité de ética para indicadores. Cada métrica se examina preguntando:

- ¿Es Predictiva de algo que nos importe (por ejemplo, de futuros incidentes graves)?
- ¿Es Relevante para los objetivos fijados o solo interesante de forma académica?
- ¿Es Accionable: su variación conduce a decisiones concretas?
- ¿Es Genuina, es decir, refleja la realidad y no una versión cosmética?
- ¿Es Significativa para los públicos clave (dirección, regulador, ciudadanía)?
- ¿Es suficientemente Precisa para soportar decisiones?
- ¿Es Oportuna: podemos disponer de ella con la frecuencia necesaria?
- ¿Es razonablemente Independiente de sesgos y manipulaciones?
- ¿Es Rentable de medir en relación con su utilidad?

El resultado es una especie de semáforo de calidad. Que una métrica sea técnicamente posible no significa que merezca vivir en el cuadro de mando nacional.

3. Ejemplo: el viaje del MTDD por GQM + PRAGMATIC

Tomemos el MTDD nacional como ejemplo. El objetivo (G1) es reducir el tiempo de detección de incidentes significativos. La pregunta (Q1.1) es evidente: “¿Con qué rapidez detectamos los incidentes críticos?”. La métrica (M1.1) cae por su propio peso.[web:24]

Pasado por el filtro PRAGMATIC, el MTDD resulta altamente predictivo, relevante y accionable: si empeora, alguien tiene que explicar por qué; si mejora, suele haber detrás cambios concretos (nuevas fuentes de telemetría, mejores reglas, automatización).[web:22] Su talón de Aquiles suele ser la precisión y la oportunidad: no todas las organizaciones registran de forma consistente el momento de ocurrencia, el momento de primera evidencia y el de detección formal.

La moraleja es que incluso una métrica “estrella” necesita disciplina de datos para brillar. El marco GQM + PRAGMATIC obliga a explicitar esas condiciones.

4. De la teoría al tablero nacional

A nivel nacional, este enfoque permite construir un tablero que no sea simplemente una agregación indiscriminada de números de SOC, sino un relato coherente: objetivos claros, preguntas relevantes, métricas evaluadas críticamente. El regulador puede explicar por qué prioriza ciertas métricas en la supervisión y deja otras en segundo plano.[web:39][web:42]

Para las organizaciones, el mismo marco sirve como guía interna: si una métrica no pasa el test PRAGMATIC, quizá no debería ocupar tiempo de los analistas; si una pregunta importante carece de métrica fiable, ahí hay un hueco de instrumentación que abordar. En ambos casos, la conversación pasa de “cuántos indicadores tenemos” a “qué decisiones respaldan estos indicadores”.

5. Un antídoto contra el dashboardismo

En última instancia, el matrimonio entre GQM y PRAGMATIC pretende ser un antídoto contra el **dashboardismo**: esa inclinación moderna a creer que cuantos más gráficos hay en una pared, más segura está la organización. La experiencia con incidentes reales y con marcos como NIS2 y ENS demuestra lo contrario: menos indicadores, pero mejor seleccionados, interpretados y alineados con objetivos, suelen dar mejores resultados.[web:39][web:36]

Si este marco logra que, en alguna sala de reuniones, alguien pregunte “¿esta métrica qué pregunta responde exactamente y a qué objetivo sirve?” antes de añadir otro gráfico, ya habrá cumplido una parte digna de su misión.